

Is My Website Hacked?

A Plain-English Guide to WP Sentinel

For small businesses and site owners who want to check a WordPress website for malware themselves, step by step, from setting up for the first time to cleaning up and staying safe.

WP Sentinel 0.25 · wp-sentinel.co.uk
Made by Little Web Shack · littlewebshack.com
Free and open source under the MIT licence

What's in this guide

1	Before you start	What Sentinel does, what it can't do, and when to get help
2	One-time setup	Python, Sentinel, your SSH key, and the Wordfence key
3	Your first scan	Fill in the form, test, scan
4	Reading your report	What the priorities mean, and what's usually harmless
5	"I think I've been hacked"	A step-by-step route through a clean-up
6	Staying safe afterwards	Regular scans and good habits
7	When it goes wrong	Common messages and how to fix them
A	Commands, if you prefer typing	The same steps without the window
B	Words you'll meet	A short glossary

How to use this guide

If you're setting up for the first time, read chapters 1 to 4 in order. They take you from nothing to a finished scan and a report you can understand.

If you already think your site has been hacked, still do chapters 1 to 3 first, because you need a working scan, then follow chapter 5 step by step.

> **GOOD TO KNOW**
> You don't need to be technical. Everything in chapters 1 to 6 is done by filling in a form and pressing buttons. The few places where you type something are shown exactly, ready to copy.

Which window am I in?

If you ever type commands, you may have two windows open that look almost the same: one on your own computer, and one logged in to your hosting server. Sentinel only runs on **your computer**. Before pressing Enter, glance at the start of the line:

✓ Your computer: run Sentinel here

```
PS C:\Users\YOU\Documents\WP Sentinel>
```

Starts with `PS C:\`.

✗ The server: not here

```
u1234-abcd@uk80.siteground.eu:~$
```

Shows your username, an `@` and the server's name.

Typed a command in the server window by mistake? You'll usually see "*invalid choice*", "*No such file or directory*" or "*command not found*". Nothing is harmed. Type `exit` and press Enter to leave the server, then try again. The WP Sentinel window always runs on your computer, so it avoids this altogether.

1 Before you start

Five minutes here will save you hours later.

What WP Sentinel does

Sentinel runs on **your own computer**. It connects to your website's hosting account over a secure connection called **SSH**, looks through every file of your WordPress site, and brings back a report. It also:

- compares WordPress itself, and your plugins and themes, with the official copies, so files that have been changed stand out
- checks your installed versions against a public list of known security holes, to help you find *how* an attacker got in
- remembers each scan, so next time it can tell you exactly which files have been added, changed or removed
- keeps every report on your computer, sealed so you can prove later that nobody has altered it

Why it runs from your computer, not as a plugin

A security plugin runs inside the website it's checking. If the site has been hacked, the attacker can switch the plugin off, hide files from it or change its results, and a badly broken site can't run the plugin at all. Sentinel never runs anything on your site and keeps its evidence away from it, so a hacked site can't interfere.

What it can't do

- **A clean report isn't a guarantee.** Sentinel looks for known warning signs. A clever attacker can hide from any scanner.
- **It doesn't fix things automatically.** It shows you what's wrong and helps you decide. Every change to your site is your decision.
- **It needs SSH.** Most hosts include SSH, but some cheaper plans don't. Chapter 2 shows you how to check.

> **STOP AND GET PROFESSIONAL HELP IF...**
>
> - your site takes payments or stores customer details, and you think it's been hacked. You may have legal duties, such as reporting a data breach.
> - the site keeps getting reinfected after you've cleaned it
> - your host has suspended the site, or Google is warning visitors away from it, and you need it back quickly
>
> Your host is a good first call. Many offer malware clean-up, and they can see things Sentinel can't.

The golden rule: back up first

Before you change anything, make a backup of your whole site, files *and* database, and keep it somewhere other than the website. Most hosts have a backup button in their control panel. A backup of a hacked site is still useful: it's your safety net if a clean-up goes wrong, and it's evidence.

2 One-time setup

You only do this once. Allow about 30 minutes. After this, each scan is a couple of clicks.

Step 1: Install Python

Sentinel is written in Python, a free programming language. You don't need to learn it; Sentinel just needs it to be installed.

1. Go to **python.org/downloads** and download Python 3 for Windows (or Mac).
2. Run the installer. If it offers **"Add python.exe to PATH"**, tick it.
3. To check it worked, open the Start menu, type **PowerShell**, open it, and type:

   ```
   python --version
   ```

   You should see something like `Python 3.14.0`. If you see "Python was not found", see chapter 7.

Step 2: Get WP Sentinel

1. Download WP Sentinel from **wp-sentinel.co.uk**.
2. Unzip it into a folder you'll find again, such as `Documents\WP Sentinel`.

That's it. Sentinel doesn't need installing; it runs from that folder. Your scans will also be saved there, in a folder called `sentinel-evidence`.

Step 3: Find your SSH details

Log in to your hosting control panel and find the **SSH** page. You need four things from it. Write them down:

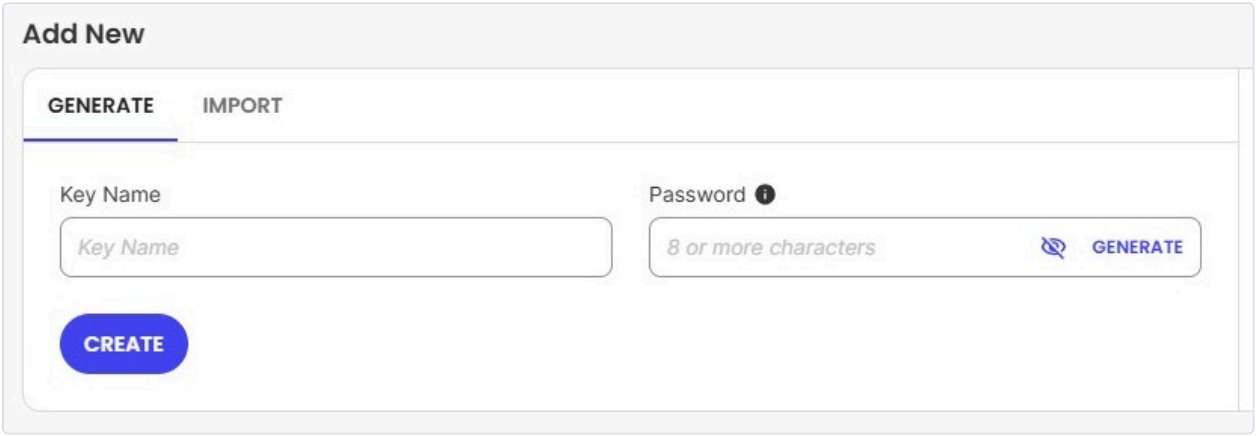
What	Looks like	Notes
Username	`u1234-abcd`	Often different from your control panel login
Server (hostname)	`uk80.siteground.eu`	A name, not a web address. No https://
Port	`18765` or `22`	The **SSH** port. Not 21, which is FTP
Site folder	`/home/customer/www/example.com/public_html`	Where your WordPress files live on the server

Step 4: Create your SSH key

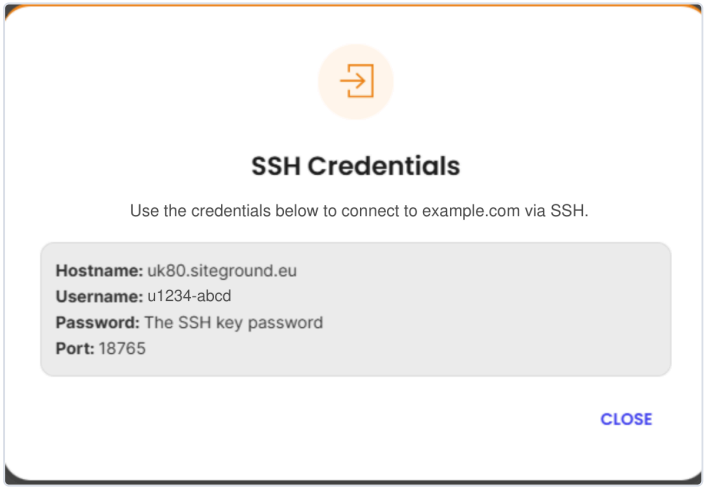
An SSH key is like a very long password stored in a file. Your host keeps one half, the public key, and you keep the other half, the private key, on your computer. You also protect it with a **passphrase**, so a stolen copy is useless on its own.

On SiteGround

1. Open **Site Tools** for your site, then **Devs › SSH Keys Manager**.
2. Under **Add New**, on the **Generate** tab, give the key a name, such as *sentinel*. In **Password**, choose a passphrase you'll remember: SiteGround calls it a password. Press **Create**.
3. In the list of keys, open the menu next to your key and choose **SSH Credentials**. This shows your username, hostname and port for Step 3.
4. Open the same menu and choose **Private Key**. Copy all of the text, including the `-----BEGIN` and `-----END` lines.



Creating a key in SiteGround's SSH Keys Manager.



SSH Credentials shows the details for Step 3. Yours will show your own username and server.

On hosts with cPanel

Go to **Security › SSH Access › Manage SSH Keys**. Choose **Generate a New Key** and set a passphrase. Back on the list, **Authorize** the new public key, then **View/Download** the private key. Some hosts need you to ask support to switch SSH on first, and to tell you the port.

Other hosts

Search your host's help pages for "SSH key". If your plan has no SSH at all, ask your host whether it can be switched on. Sentinel can't scan without it.

Step 5: Save the private key on your computer

1. Open your user folder, `C:\Users\YOUR-NAME`. If there's no folder called `.ssh`, create one, with the dot at the start.
2. Open **Notepad** and paste the private key text.
3. Choose **File › Save as**. Set **Save as type** to **All files**, go to the `.ssh` folder and name the file after your site, such as `mysite_key`. There's no `.txt` at the end.

> **CAREFUL**
>
> This file is the key to your hosting account. Never email it, upload it to your website or share it. If you think someone has a copy, delete the key in your host's control panel and make a new one.

Step 6: Get a free Wordfence key (optional, but recommended)

This lets Sentinel check your plugin and theme versions against Wordfence's public list of known security holes. It's often how attackers get in, so it's well worth doing.

1. Create a free account at **wordfence.com** and sign in.
2. Find the option to create a **Vulnerability Data Feed API key**. At the time of writing it's under your account's **Integrations** page; if it has moved, search Wordfence's help for that name. The key is shown only once, so copy it straight away.
3. Save it the same way as your SSH key: in Notepad, with only the key in the file, saved into your `.ssh` folder as `wordfence_key` with "All files" as the type.

The key only ever goes to Wordfence. Sentinel never puts it in reports or on your website.

3 Your first scan

Now the fun part. This is where all that setup pays off.

Open WP Sentinel

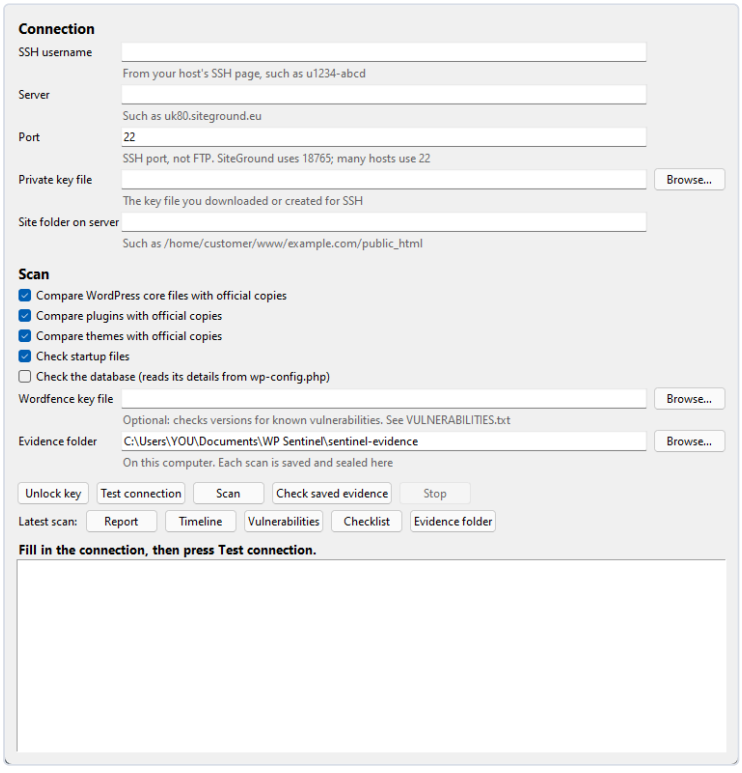
1. Open your WP Sentinel folder in File Explorer.
2. Right-click an empty space in the folder and choose **Open in Terminal**. On older Windows, click the address bar, type `powershell` and press Enter.
3. Type this and press Enter:

```
python sentinel-app.py
```

The WP Sentinel window opens. Leave the terminal window open behind it while you work.

> **CAREFUL: YOUR COMPUTER, NOT THE SERVER**
>
> Always run Sentinel on **your own computer**. If your terminal shows a line like `PS C:\Users\...>`, you're in the right place. If it shows something like `u1234-abcd@uk80.siteground.eu:~$`, you're logged in to the server. Type `exit` to get back. See "Which window am I in?" on page 2.

Fill in the form



The WP Sentinel window the first time you open it.

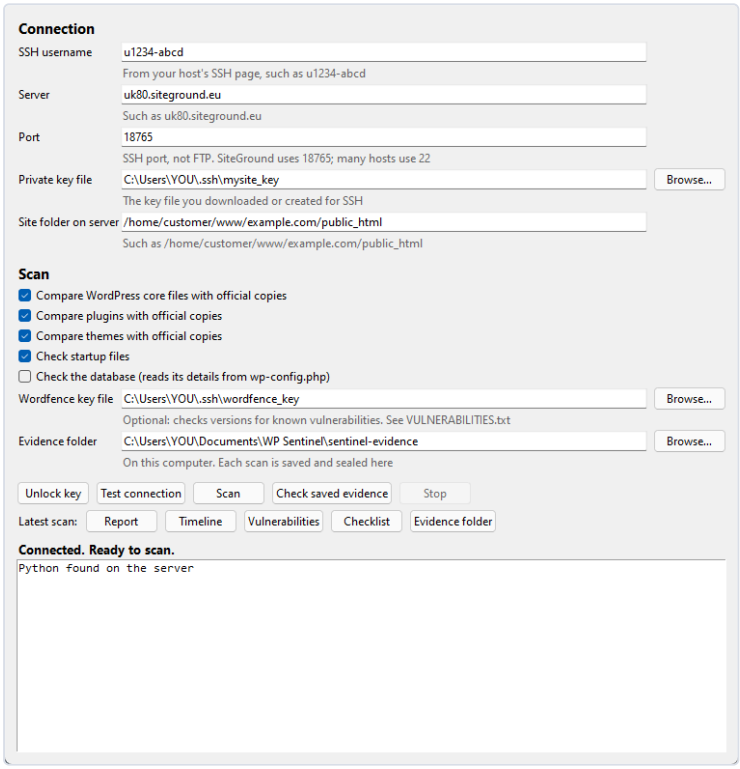
1. **SSH username, Server, Port**: copy these from your host's SSH page, as in chapter 2, step 3.
2. **Private key file**: press **Browse...** and choose the key you saved in your `.ssh` folder.
3. **Site folder on server**: the full path, starting with `/`.

4. **Scan options**: leave the first four ticked. Tick **Check the database** too if you want the most thorough scan; it reads the database details from your site's settings file, so you don't need to type a password.
5. **Wordfence key file**: press **Browse...** and choose `wordfence_key`, if you made one.
6. **Evidence folder**: leave this as it is.

Sentinel remembers all of this for next time. It never saves your passphrase.

Unlock your key and test the connection

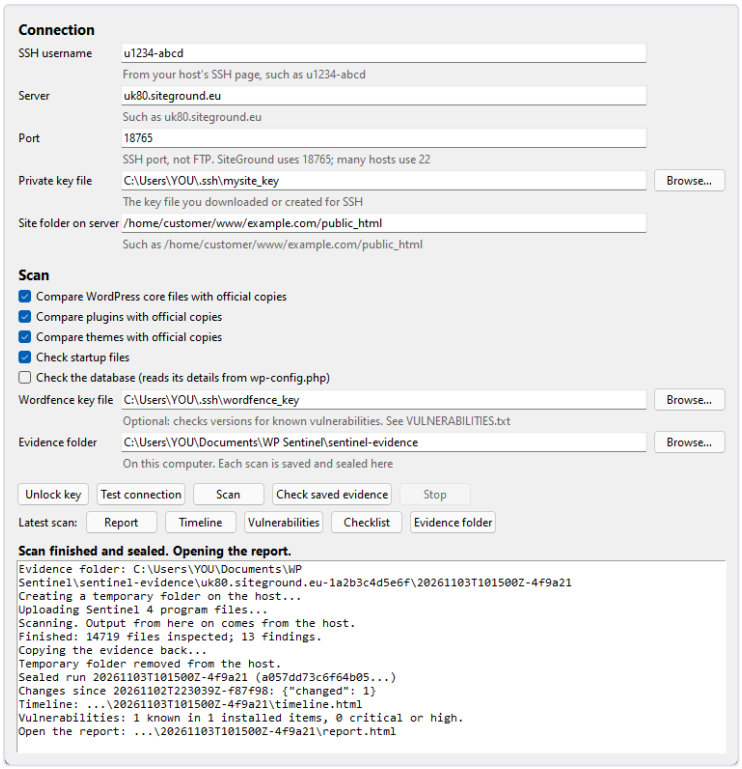
1. Press **Unlock key**. A small black window opens and asks for your passphrase. Type it and press Enter. Nothing appears as you type; that's normal. The key stays unlocked until you restart your computer.
2. Press **Test connection**.
3. The first time only, Sentinel says this computer hasn't met the server before and offers to open a window. Say yes. The window shows the server's *fingerprint*, a long code that proves you're talking to the real server. If your host publishes its fingerprint, check they match. Type `yes` and press Enter, then close the window and press **Test connection** again.



"Connected. Ready to scan." means everything is set up.

Scan

Press **Scan**. A typical site takes a few minutes. Progress appears in the box at the bottom. When it's finished, your report opens in your web browser.



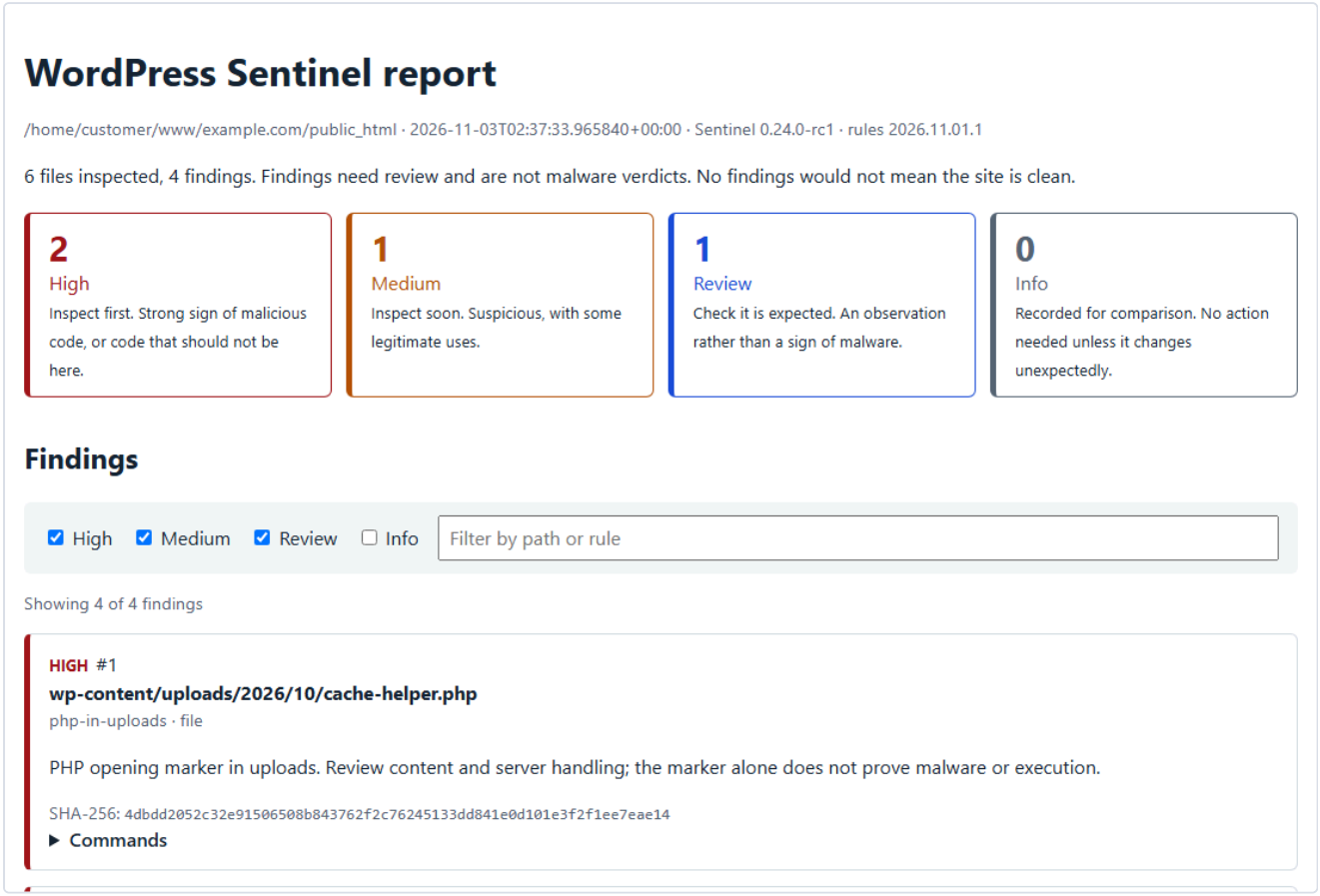
A finished scan. The last lines summarise what changed and what was found.

The buttons under **Latest scan** open the pages for your newest scan:

Button	What it shows
Report	Everything the scan found, most important first
Timeline	When files were changed, day by day, and anything unusual about them
Vulnerabilities	Known security holes in your installed versions, and the version that fixes each one
Checklist	A clean-up checklist built from this scan, for use after a hack (chapter 5)
Evidence folder	Opens the folder where every scan is kept

4 Reading your report

Most findings on a healthy site are harmless. This chapter helps you tell which ones need a closer look.



A report from a made-up example site. The coloured boxes at the top count findings by priority.

The four priorities

Priority	What it means	What to do
High	A strong sign of malicious code, or code where it shouldn't be	Look at these first
Medium	Suspicious, but some legitimate software does this too	Look soon
Review	An observation, not a sign of malware	Check it's something you expect
Info	Recorded so a change stands out next time	Nothing, unless it changes

Each finding shows the file, the rule that noticed it, and a sentence explaining why. The tick boxes and filter at the top let you hide what you've already checked.

Usually harmless

- **"Verified official"**: the file is identical to the official copy, so the pattern it matched is part of the original software.
- **advanced-cache.php or object-cache.php** (a "drop-in"): normally written by a caching plugin or your host.
- **.htaccess files** in WordPress folders, and **extra files in a security plugin's folder**: often added by your host's security tools, such as SiteGround Security.
- **"Unverified" plugins or themes**: premium or custom software that has no public official copy to compare with. That isn't a problem in itself; it just means Sentinel can't vouch for it.
- **Image markers** (info): a few bytes in a picture that happen to look like code.

Take seriously

- **PHP files in uploads**. Uploads should hold pictures and documents, not code. This is one of the most common hiding places for malware.
- **Unknown PHP files in the site's main folder** or directly in `wp-content`, especially with names that sound official but aren't, such as `wp-login-check.php`.
- **WordPress core files that differ from the official copy**, when you haven't edited them yourself.
- **New administrator accounts** you don't recognise (database check).
- **Lots of changed or added files** since your last scan when you didn't update anything.

> **GOOD TO KNOW**
> The first report on any site has a few findings to get used to. Once you've checked them, what matters most is **what changes from one scan to the next**. Something new is far more interesting than something that's been there, unchanged, for months.

What changed since last time

From your second scan on, the last lines in the window include something like:

```
Changes since 20261102T223039Z-f87f98: {"changed": 1}
```

That means one file is different from the previous scan. *Added* means new files, and *missing* means removed ones. After you update WordPress or a plugin, expect plenty of changes. When you haven't touched the site, a log file or cache file changing is normal, but new PHP files are worth investigating.

The Timeline and Vulnerabilities pages

Timeline shows how many files changed on each day. A sudden burst on a day when nobody updated anything is a clue, and it can tell you roughly when a hack happened. That date helps you pick a clean backup.

Vulnerabilities lists known security holes in your installed versions, with how serious each is and which version fixes it. Anything marked **Critical** or **High** should be updated, or the plugin removed, straight away.

5 "I think I've been hacked"

Take a breath. Work through these steps in order. Don't skip ahead to deleting things.

1. **Back up everything, as it is now.** Use your host's backup tool to save the files and database, even though they're infected. This is your safety net and your evidence.
2. **Run a full scan.** Tick every option, including the database, and make sure your Wordfence key file is filled in.
3. **Find the way in.** Open **Vulnerabilities**. A plugin or theme with a known hole is the most common way attackers get in. If you remove the malware but leave the hole open, the site usually gets hacked again within days.
4. **Find out when it started.** Open **Timeline** and look for the day the suspicious files appeared. Make a note of it.
5. **Clean the site.** Choose one of the routes on the next page.
6. **Close the hole.** Update or remove whatever the Vulnerabilities page named. Remove plugins and themes you don't use.
7. **Work through the Checklist.** Press **Checklist**. It's built from your scan and covers what's easy to forget: changing passwords and security keys, signing everyone out, clearing caches and watching for the hack coming back. Tick items off as you go.
8. **Scan again.** The new report should show the bad files gone and nothing new. Scan again over the next few days to be sure the hack hasn't come back.

Choosing how to clean

A. Restore a clean backup

Easiest, if you have one. Restore a backup from *before* the date you found on the Timeline, then immediately update everything and close the hole (step 6). Anything added to the site since that backup will need adding again.

B. Reinstall and remove

Good for most people. Reinstall WordPress from *Dashboard › Updates › Re-install*, and delete and reinstall affected plugins from the Plugins page. Then delete the files that shouldn't exist, such as PHP in uploads, using your host's File Manager. Keep a copy of each before deleting it.

C. Quarantine with Sentinel

Good for files that shouldn't be there, such as PHP files in uploads. Press **Quarantine** to move them out of your website into a private folder, with an undo. See the next page. Swapping changed WordPress or plugin files for clean copies still uses typed commands: *CLEAN-REPLACEMENT.txt*.

D. Get help

No shame in it. Your host may offer a malware clean-up service. Give them your Sentinel report; it saves them time. For sites holding customer data or taking payments, a professional incident response is worth the cost.

CAREFUL

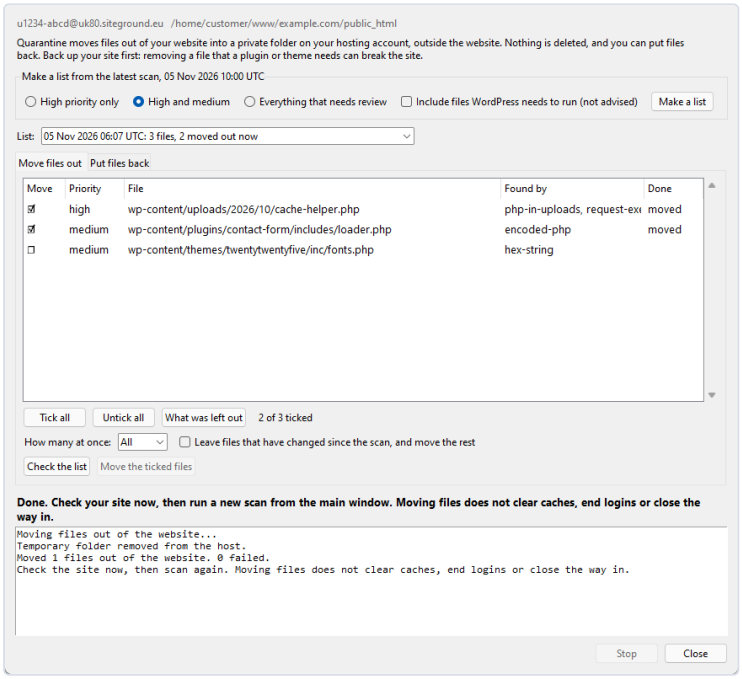
Deleting the wrong file can take your site offline. Before deleting anything, check it isn't part of a plugin or theme you use, and keep a copy. If you're unsure, route A or D is safer.

Moving bad files out with Quarantine

Quarantine moves files out of your website into a private folder on your hosting account, called `wp-sentinel-private`, outside the website. Nothing is deleted, so a file you move by mistake can be put back. Back up first, as in step 1.

Press **Quarantine** under **Latest scan**. It works from your newest scan, so scan first.

1. **Make a list.** Start with **High priority only** and press **Make a list**. Nothing on your website changes yet. Files WordPress needs in order to run are left out on purpose; **What was left out** shows them, with the reason.
2. **Untick anything you want to keep.** If a file belongs to a plugin or theme you use and you're not sure it's bad, untick it and ask for help with that one.
3. **Press Check the list.** Sentinel checks every ticked file on the server. If a file has changed since your scan, it's flagged: the attacker may still be active, so look at it before going on.
4. **Press Move the ticked files** and confirm. The button only works after a check of exactly the files ticked, so a stray click can't move the wrong ones.
5. **Look at your website straight away**, then scan again from the main window.



Two files moved out. The third was unticked, so it stays on the site.

IF THE SITE BREAKS

Open the **Put files back** tab, tick the file the site needs, press **Check**, then **Put back the ticked files**. Put back only what you need: a file put back is active again, malware and all. Leave the `wp-sentinel-private` folder on the server alone, because putting files back needs it.

Passwords and keys to change

The Checklist covers these in detail, but here's the short version. Change them **after** the site is clean, or the attacker may simply read the new ones:

- every WordPress administrator's password, and remove any administrators you don't recognise
- your WordPress security keys, called "salts". A free salt-changing plugin, or your host, can do this. It signs everyone out.
- your database password, hosting control panel password, FTP and SSH passwords, and email accounts on the same hosting
- API keys stored in plugins, such as payment, email and analytics keys

6 Staying safe afterwards

A few small habits stop most attacks before they start.

A simple routine

When	What
Every week	Open WP Sentinel and press **Scan**. Look at what changed. If nothing new appears in the report, you're done.
After updates	Scan again, so the next scan's changes only show what happened since.
Every month	Press **Check saved evidence**. It confirms none of your saved scans has been altered.
Always	Keep WordPress, plugins and themes up to date. Remove anything you don't use. Use strong, unique passwords and two-factor sign-in for administrators.

Look after your evidence folder

Your `sentinel-evidence` folder is the history of your site. It's what lets Sentinel spot changes, and it lets you prove what was found and when.

- **Keep it in one place.** If you move it, move the whole folder and point the **Evidence folder** box at its new home.
- **Never merge two copies.** Copying one evidence folder over another breaks the link between scans. **Check saved evidence** will tell you if this has happened.
- **Back it up** with the rest of your files.
- **Keep it private.** Reports list your site's files and settings. Never upload them to your website.

Automatic scans and alerts

Sentinel can also scan on a schedule and email you only when something new turns up. Setting that up involves a settings file and a scheduled task, so it's covered in *MONITORING.txt* in the documentation folder rather than here. A weekly scan with the window is a fine place to start.

7 When it goes wrong

Every one of these has caught out a real person setting Sentinel up. You're in good company.

What you see	What it means and what to do
"Python was not found; run without arguments to install from the Microsoft Store"	Python isn't installed, or Windows can't find it. Install it from python.org (chapter 2, step 1) and tick "Add python.exe to PATH". Then close the terminal and open a new one.
"invalid choice", such as `invalid choice: 'restore'`	You're typing in the server window, which may hold an older copy of Sentinel. Type `exit`, and run the command in a `PS C:\` window on your computer. See "Which window am I in?" on page 2.
"No such file or directory" when starting Sentinel	The terminal isn't in your WP Sentinel folder, or you're logged in to the server. Check the prompt starts with `PS C:\` and shows your Sentinel folder.
"Connection refused" to `127.0.0.1`	`127.0.0.1` always means "this computer". Put your host's server name in the Server box, such as `uk80.siteground.eu`.
"Could not connect", or **no answer after 60 seconds**	Usually the wrong port. Use the SSH port from your host's SSH page: not 21, which is FTP. SiteGround uses 18765. Also check the server name has no https:// or slashes.
"The server refused the login"	Press **Unlock key** and type your passphrase, then test again. If it still fails, check the username, and that you chose the right key file. Some hosts take a few minutes to activate a new key.
"Identity file ... not accessible"	The key file isn't where the form says. Press **Browse...** and choose it again.
"This computer has not met this server before"	Normal the first time. Say yes, check the fingerprint, type `yes`. See chapter 3.
"The OpenSSH Authentication Agent is not running"	Windows' key-unlocking service is switched off. It needs switching on once, by someone with administrator rights. See below.
Vulnerability check "skipped: no API key" or "key refused"	Choose your Wordfence key file in the form. If it's refused, check the file holds only the key, with nothing else, or make a new key on wordfence.com.
You pressed **Stop** during a scan	A temporary folder starting `.sentinel-run-` may be left in your home folder on the server. Delete it with your host's File Manager.
Quarantine says files **"have changed since the scan"**	Something changed them after you scanned. That needs a look, as the attacker may still be active. Scan again and make a new list, or untick those files.

Quarantine says **"Store is locked"**	A quarantine step was stopped part way. Wait a minute and try again. If it persists, see "Interruptions" in *QUARANTINE.txt*.
Check saved evidence lists folders "not covered by a chain"	Usually scans that stopped early, which are harmless, or an evidence folder that was copied over another. See "Look after your evidence folder" in chapter 6.

Switching on the key-unlocking service

On Windows, open the Start menu, type **PowerShell**, right-click it and choose **Run as administrator**. Type these two lines:

```
Get-Service ssh-agent | Set-Service -StartupType Automatic
Start-Service ssh-agent
```

Close that window. Use a **normal** PowerShell window, not an administrator one, for everything else. Files Sentinel creates from an administrator window can end up locked away from your normal account.

On a Mac

The window works the same way. Where Windows opens a small window for your passphrase or the server's fingerprint, the Mac version shows you a command to paste into the Terminal app instead.

A Commands, if you prefer typing

Everything the window does can be typed instead. Run these in a terminal in your WP Sentinel folder, on your own computer.

Scan

```
python sentinel-remote.py scan --host u1234-abcd@uk80.siteground.eu --port 18765 --identity
C:\Users\YOU\.ssh\mysite_key --root /home/customer/www/example.com/public_html --core --plugins
--themes --persistence --vuln-key-file C:\Users\YOU\.ssh\wordfence_key
```

Add `--db-from-wp-config` to check the database as well.

Unlock your key

```
ssh-add C:\Users\YOU\.ssh\mysite_key
```

Check saved evidence

```
python sentinel-remote.py verify
```

Make the clean-up checklist for a scan

```
python sentinel-remote.py checklist --run sentinel-evidence\SITE-FOLDER\RUN-FOLDER
```

The site and run folder names are shown in the window's output after each scan.

Quarantine

Add the same `--host`, `--port`, `--identity` and `--root` as for a scan to each of these. Make a list from a scan, check it, then move its files:

```
python sentinel-remote.py quarantine-plan ... --run sentinel-evidence\SITE-FOLDER\RUN-FOLDER
python sentinel-remote.py quarantine ... --plan LIST-FOLDER
python sentinel-remote.py quarantine ... --plan LIST-FOLDER --apply --plan-sha256 HASH
```

Each command prints the next one to type. To put files back, use `restore` in place of `quarantine`. *REMOTE.txt* has the details.

Scan every WordPress site on your hosting account

```
python sentinel-remote.py scan-all --host u1234-abcd@uk80.siteground.eu --port 18765 --identity
C:\Users\YOU\.ssh\mysite_key --core --plugins --themes --persistence
```

Where to read more

Guide, in the documentation folder	Covers
APP.txt	The WP Sentinel window and Quarantine in more detail
REMOTE.txt	Scanning from your computer, evidence and its limits
RULES.txt	Everything the scan checks for
VULNERABILITIES.txt	The Wordfence check
CHECKLIST.txt	The post-incident checklist
CLEAN-REPLACEMENT.txt, BATCH-QUARANTINE.txt	Sentinel's repair tools
MONITORING.txt	Scheduled scans and email alerts
ACCOUNT.txt	Scanning several sites on one account

B Words you'll meet

Word	Meaning
SSH	A secure way for one computer to log in to another and run commands. Sentinel uses it to reach your hosting account.
SSH key	A pair of matching files that work like a very long password. The *public* half sits with your host; the *private* half stays on your computer.
Passphrase	The password that protects your private key file.
Port	A numbered door on the server. SSH and FTP use different doors, so the number matters.
Fingerprint	A short code identifying a server, so you know you're connecting to the real one.
Malware	Any software put on your site to do harm, such as sending spam, redirecting visitors or stealing data.
Backdoor	A hidden file that lets an attacker back in, even after passwords are changed.
Vulnerability	A known flaw in a version of some software that attackers can use to get in. Usually fixed by updating.
Core	WordPress itself, as opposed to plugins and themes.
Drop-in	A special file in `wp-content` that changes how WordPress works, often used by caching plugins.
Salts	Secret values in your site's settings that keep logins secure. Changing them signs everyone out.
Hash	A fingerprint of a file's contents. If even one character of the file changes, the hash changes completely.
Evidence, sealed	Sentinel records a hash of every report and links each scan to the one before, so any later change can be detected.
Quarantine	Moving a suspicious file somewhere safe and private instead of deleting it, so it can be examined, or put back if it was innocent.

ABOUT WP SENTINEL

WP Sentinel is free, open-source software, released under the MIT licence. It's provided as it is, with no warranty: it helps you find problems, but the decisions and any changes to your site are yours.

Updates, news and this guide: **wp-sentinel.co.uk**. Made by **Little Web Shack**, littlewebshack.com.